

REPORT DI LABORATORIO – SICUREZZA INFORMATICA

Esplorazione di Processi, Thread, Handle e Registro di Windows tramite Sysinternals Suite

1. INTRODUZIONE

Obiettivo del laboratorio:

Acquisire competenze pratiche nell'analisi di sistemi Windows utilizzando strumenti avanzati di amministrazione e diagnostica. In particolare, il laboratorio si è concentrato su:

- L'analisi dei processi attivi e delle loro gerarchie
- L'esplorazione di thread e handle all'interno dei processi
- La comprensione della struttura e delle funzioni del Registro di Windows
- L'utilizzo di Process Explorer (Sysinternals Suite) per attività di incident response e analisi malware

Strumenti utilizzati:

- Process Explorer (procexp.exe) – Microsoft Sysinternals Suite
- Editor del Registro di sistema (regedit.exe) – Windows built-in
- Prompt dei Comandi (cmd.exe) – Windows built-in

Ambiente di laboratorio:

- Sistema Operativo: Windows 10/11
 - Browser utilizzato: Microsoft Edge
 - Utente: Amministratore locale
-

2. PARTE 1 – ESPLORAZIONE DEI PROCESSI

2.1 Passo 1 – Introduzione a Process Explorer

Process Explorer è stato avviato dalla cartella SysinternalsSuite. L'applicazione fornisce una visualizzazione dettagliata di tutti i processi in esecuzione, inclusi quelli nascosti nella normale Task Manager.

2.2 Passo 2 – Esplorare un processo attivo (Browser Web)

Procedura:

1. È stato aperto Microsoft Edge.
2. Utilizzando l'icona "Find Window's Process" (mirino) di Process Explorer, è stato identificato il processo msedge.exe.
3. Il processo è stato terminato tramite l'opzione Kill Process.

Domanda 1: Cosa è successo alla finestra del browser web quando il processo è stato terminato?

Risposta:

La finestra del browser è scomparsa immediatamente senza alcun messaggio di avviso o conferma. Tutte le schede aperte sono state chiuse forzatamente senza possibilità di salvare i dati. Il processo msedge.exe è stato rimosso completamente dalla memoria e dall'elenco di Process Explorer, senza lasciare processi "orfani" o zombie.

Osservazione tecnica:

A differenza di una chiusura normale (clic sulla X) che invia un messaggio WM_CLOSE al processo per consentire un salvataggio ordinato, l'operazione Kill Process esegue una terminazione forzata (TerminateProcess API), che non dà al processo il tempo di salvare lo stato o rilasciare risorse.

2.3 Passo 3 – Avviare un altro processo (Prompt dei Comandi e Ping)

Procedura:

1. È stato aperto un Prompt dei Comandi (cmd.exe).
2. Utilizzando il mirino di Process Explorer, è stato localizzato cmd.exe.
3. È stata osservata la gerarchia: explorer.exe (genitore) → cmd.exe → conhost.exe.
4. Nel Prompt dei Comandi è stato avviato il comando: ping -t 8.8.8.8.

Domanda 2: Cosa è successo durante il processo ping?

Risposta:

Durante l'esecuzione del comando ping, è apparso un nuovo processo figlio chiamato `ping.exe` sotto `cmd.exe` nella struttura ad albero di Process Explorer. Questo processo ha:

- Consumato risorse di rete per inviare/ricevere pacchetti ICMP
- Utilizzato una minima quantità di CPU
- Mostrato l'output in tempo reale nella finestra del Prompt dei Comandi
- Mantenuto attiva la connessione di rete fino all'interruzione del comando

Struttura ad albero osservata:

```
text
explorer.exe
├── cmd.exe
│   ├── conhost.exe
│   └── ping.exe
```

Domanda 3: Cosa è successo al processo figlio `conhost.exe` quando è stato terminato `cmd.exe`?

Risposta:

Quando `cmd.exe` è stato terminato tramite Kill Process, il processo figlio `conhost.exe` è stato terminato automaticamente insieme al processo padre. Anche `ping.exe` (se ancora in esecuzione) è stato terminato. La finestra del Prompt dei Comandi si è chiusa immediatamente.

Concetto chiave:

In Windows, quando un processo padre viene terminato forzatamente, il sistema operativo termina tutti i processi figli associati (a meno che non siano stati "staccati" con funzioni specifiche come `PROCESS_DETACH`). Questo è importante per comprendere la persistenza dei processi in caso di attacchi malware.

3. PARTE 2 – ESPLORAZIONE DI THREAD E HANDLE

3.1 Passo 1 – Esplorare i thread di `conhost.exe`

Procedura:

1. È stato selezionato `conhost.exe` in Process Explorer.
2. Tramite Properties → Threads, sono stati esaminati i thread attivi.

Domanda 4: *Che tipo di informazioni sono disponibili nella finestra Proprietà (scheda Threads)?*

Risposta:

La finestra Proprietà fornisce le seguenti informazioni per ciascun thread:

Colonna/Informazione	Descrizione
TID (Thread ID)	Identificatore univoco del thread
Start Address	Indirizzo di memoria dove il thread ha iniziato l'esecuzione
Priority	Priorità del thread (più alto = più importante)
Base Priority	Priorità di base assegnata dal sistema
CPU	Percentuale di CPU utilizzata dal thread
Cycles	Cicli di clock consumati
State	Stato del thread (Running, Wait, Ready, Terminated)
Wait Reason	Motivo per cui il thread è in attesa (se applicabile)
Context Switches	Numero di cambi di contesto tra thread
Kernel Time / User Time	Tempo speso in modalità kernel vs. modalità utente

Start Time	Orario di avvio del thread
Stack	Traccia delle funzioni chiamate (call stack) – utile per il debug e l'analisi malware

Osservazione tecnica:

Il processo `conhost.exe` (Console Window Host) gestisce l'interfaccia utente della console. I suoi thread gestiscono funzioni specifiche come:

- Input da tastiera
- Rendering del testo
- Gestione del buffer della console
- Aggiornamento della finestra
- Sincronizzazione tra thread tramite eventi

3.2 Passo 2 – Esplorare gli handle di `conhost.exe`

Procedura:

1. In Process Explorer, è stata attivata la vista View → Lower Pane View → Handles.
2. Sono stati esaminati gli handle associati a `conhost.exe`.

Domanda 5: A cosa puntano gli handle?

Risposta:

Gli handle sono riferimenti a risorse di sistema gestite dal kernel. Per `conhost.exe`, gli handle osservati puntano a:

Tipo di Handle	Esempio	Spiegazione
File	<code>\Device\ConDrv</code>	Driver della console per input/output
Key	<code>\Registry\Machine\SOFTWARE\...\Console</code>	Chiavi del Registro per impostazioni della console

Event	<code>\KernelObjects\...</code>	Oggetti di sincronizzazione tra thread
WindowStation	<code>\Windows\WindowStations\WinSta0</code>	Stazione di lavoro del desktop
Desktop	<code>\Windows\WindowStations\WinSta0\Default</code>	Desktop predefinito
Section	Memoria condivisa	Buffer per il rendering della console

Significato per la sicurezza:

Un processo malevolo che apre handle a risorse inaspettate (es. handle a file di sistema o chiavi di registro critiche) può essere un indicatore di compromissione (IoC). Process Explorer permette di identificare tali comportamenti anomali.

4. PARTE 3 – ESPLORAZIONE DEL REGISTRO DI WINDOWS

4.1 Struttura dei cinque hive principali

Il Registro di Windows è organizzato in cinque hive principali, ciascuno con funzioni specifiche.

Hive	Descrizione	Esempio di contenuto
HKEY_CLASSES_ROOT (HKCR)	Associato a <code>HKLM\Software\Classes.</code> Memorizza associazioni file, ProgID, CLSID, IID per oggetti COM/OLE	<code>.txt</code> → <code>txtfile</code> → apre con Notepad

HKEY_CURRENT_USER (HKCU)	Impostazioni dell'utente attualmente connesso. È una sottochiave di <code>HKEY_USERS</code>	Sfondo desktop, colore finestre, preferenze applicazioni
HKEY_LOCAL_MACHINE (HKLM)	Configurazioni specifiche del computer locale (hardware, driver, servizi, software per tutti gli utenti)	Servizi di sistema, driver, chiavi di persistenza (Run)
HKEY_USERS (HKU)	Impostazioni per tutti gli utenti del computer. Ogni utente ha una sottochiave con il suo SID	Profili di tutti gli utenti, profilo <code>.DEFAULT</code>
HKEY_CURRENT_CONFIG (HKCC)	Link a <code>HKLM\SYSTEM\CurrentControlSet\Hardware Profiles\Current</code>	Profilo hardware attivo all'avvio (driver video, stampanti)

Domanda 6: *Quale hive contiene le impostazioni dell'utente corrente?*

Risposta: `HKEY_CURRENT_USER` (HKCU)

Domanda 7: *Quale hive contiene le associazioni dei file?*

Risposta: `HKEY_CLASSES_ROOT` (HKCR)

Domanda 8: *Quale hive contiene i servizi di sistema?*

Risposta: `HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services`

Domanda 9: *Perché HKCR è sia un hive separato che una sottochiave di HKLM?*

Risposta: Per compatibilità con applicazioni legacy. HKCR è un link simbolico a `HKLM\Software\Classes`. È stato mantenuto per non rompere la compatibilità con vecchi software che si aspettano di trovare le associazioni di file in HKCR.

Domanda 10: Qual è la differenza tra `CurrentControlSet` e `ControlSet001`?

Risposta:

- `CurrentControlSet` è un link simbolico che punta a uno dei `ControlSet` (es. `ControlSet001`).
 - Il sistema mantiene più `ControlSet` per poter fare rollback in caso di modifiche che rendono il sistema instabile.
 - `CurrentControlSet` punta al `ControlSet` attualmente in uso all'avvio.
-

5. ESERCIZIO 2 – MODIFICA DELLA CHIAVE `EulaAccepted`

5.1 Obiettivo

Comprendere come le applicazioni memorizzano le preferenze utente nel Registro di Windows e come la modifica di tali valori influisce sul comportamento delle applicazioni.

5.2 Procedura

Passo 1: Navigare alla chiave:

```
text
```

```
HKEY_CURRENT_USER\Software\Sysinternals\Process Explorer
```

Passo 2: Individuare il valore `EulaAccepted` di tipo `REG_DWORD`.

Passo 3: Verificare il valore attuale: `1` (EULA accettato).

Domanda 11: Qual è il valore per questa chiave di registro nella colonna Dati (Data)?

Risposta: Il valore è `0x00000001` (`1`) prima della modifica. Dopo la modifica, il valore è `0x00000000` (`0`).

Passo 4: Modificare il valore da `1` a `0` e salvare.

Passo 5: Riavviare Process Explorer.

5.3 Risultati

Domanda 12: Quando apri Process Explorer, cosa vedi?

Risposta:

All'avvio di Process Explorer, è apparsa nuovamente la finestra di dialogo dell'EULA (End User License Agreement) che chiede di accettare i termini di licenza. Questo perché il valore `EulaAccepted = 0` indica che l'utente non ha ancora accettato la licenza.

Osservazione tecnica:

Dopo aver cliccato su "Accept", Process Explorer ha:

1. Ripristinato il valore `EulaAccepted` a 1 nel Registro.
2. Avviato normalmente l'applicazione.

Questo dimostra come le applicazioni utilizzino il Registro per memorizzare preferenze e configurazioni persistenti.

6. DOMANDE DI APPROFONDIMENTO E RISPOSTE

N.	Domanda	Risposta
13	<i>Perché i programmi memorizzano le preferenze nel Registro e non in file di configurazione?</i>	Il Registro è centralizzato, accessibile a tutti i processi, supporta permessi ACL, è standardizzato su tutte le versioni di Windows, ed è più efficiente per il sistema operativo rispetto a file di configurazione sparsi.
14	<i>Cosa succederebbe se eliminassi la chiave <code>EulaAccepted</code> anziché impostarla a 0?</i>	Lo stesso comportamento: Process Explorer mostrerebbe l'EULA all'avvio, poiché la chiave non esiste e il programma considera che

		l'utente non l'abbia mai accettata.
15	<i>Qual è il vantaggio di avere preferenze in HKCU rispetto a HKLM?</i>	Ogni utente può avere impostazioni personalizzate senza influenzare gli altri; maggiore sicurezza e isolamento; se un utente corrompe le proprie impostazioni, gli altri non vengono influenzati.
16	<i>Perché i malware spesso scrivono in HKLM...\Run e non in HKCU...\Run?</i>	HKLM è globale: il malware si avvia per TUTTI gli utenti che accedono al computer. Se scrivesse solo in HKCU, si avvierebbe solo per l'utente infetto.
17	<i>Cosa succede se cancelli HKCU\Control Panel\Desktop\Wallpaper?</i>	Lo sfondo del desktop torna al colore o all'immagine predefinita di Windows. Il sistema ricrea il valore al prossimo cambio di sfondo.

7. CONCLUSIONI E COMPETENZE ACQUISITE

Al termine del laboratorio, lo studente ha acquisito le seguenti competenze:

Competenza	Descrizione
------------	-------------

Analisi dei processi	Utilizzo di Process Explorer per identificare processi attivi, gerarchie padre-figlio, e terminazione forzata dei processi.
Analisi dei thread	Esame di thread, stati, priorità, tempo CPU, e call stack per comprendere il comportamento di un processo.
Analisi degli handle	Identificazione delle risorse di sistema (file, registro, eventi, WindowStation) aperte da un processo.
Analisi del Registro	Comprensione della struttura gerarchica dei cinque hive, delle loro funzioni, e della loro importanza per la configurazione di sistema e la persistenza malware.
Modifica del Registro	Capacità di modificare chiavi di registro e osservare l'impatto sul comportamento delle applicazioni (es. EulaAccepted).
Incident Response	Utilizzo di strumenti Sysinternals per l'analisi forense di base e l'identificazione di indicatori di compromissione (IoC).

8. RACCOMANDAZIONI PER LA SICUREZZA

1. Monitorare le chiavi Run: Controllare regolarmente HKLM\...\Run e HKCU\...\Run per rilevare software sospetti che si avviano automaticamente.
2. Utilizzare Process Explorer per l'analisi: È uno strumento essenziale per individuare processi nascosti, thread sospetti e handle aperti a risorse critiche.

3. Verificare i file sconosciuti: Utilizzare la funzione Check VirusTotal in Process Explorer per analizzare file eseguibili sospetti.
 4. Backup del Registro: Prima di apportare modifiche al Registro, esportare le chiavi interessate per poter ripristinare lo stato precedente.
 5. Limitare i permessi: Utilizzare account con privilegi minimi per ridurre l'impatto di potenziali malware che tentano di modificare il Registro.
-

9. BIBLIOGRAFIA E RIFERIMENTI

- Microsoft Sysinternals Suite – Process Explorer Documentation
<https://docs.microsoft.com/en-us/sysinternals/downloads/process-explorer>
 - Microsoft – Windows Registry Structure
<https://docs.microsoft.com/en-us/windows/win32/sysinfo/structure-of-the-registry>
 - Microsoft – Registry Hives
<https://docs.microsoft.com/en-us/windows/win32/sysinfo/registry-hives>
 - SANS Institute – Windows Forensics and Incident Response
<https://www.sans.org/>
 - MITRE ATT&CK Framework – Persistence Techniques (Registry Run Keys)
<https://attack.mitre.org/techniques/T1547/001/>
-

10. FIRMA E DATA

Studente: Lorenzo Rizzuti

Data: 04/06/2026